

SecureNova Inc.

AI Identity Security Capstone

Executive Walkthrough

Prepared for: Chief Technology Officer

Prepared by: Raushan, AI Application Security Engineering

August 24, 2026

Scope and Methodology

What We Looked At

This project examined how safe SecureNova's AI customer support agent is from attacks that specifically target its "identity" — in other words, how the agent proves who it is, what it's allowed to do, and how it protects sensitive information like login credentials.

We treated the AI agent the way we'd treat any employee with system access: what could go wrong if someone tricked it, impersonated it, or manipulated what it was told to do? We tested this in a safe, contained environment — no real customer data or real money was ever at risk.

How We Tested It (in Plain Terms)

The work happened in two phases:

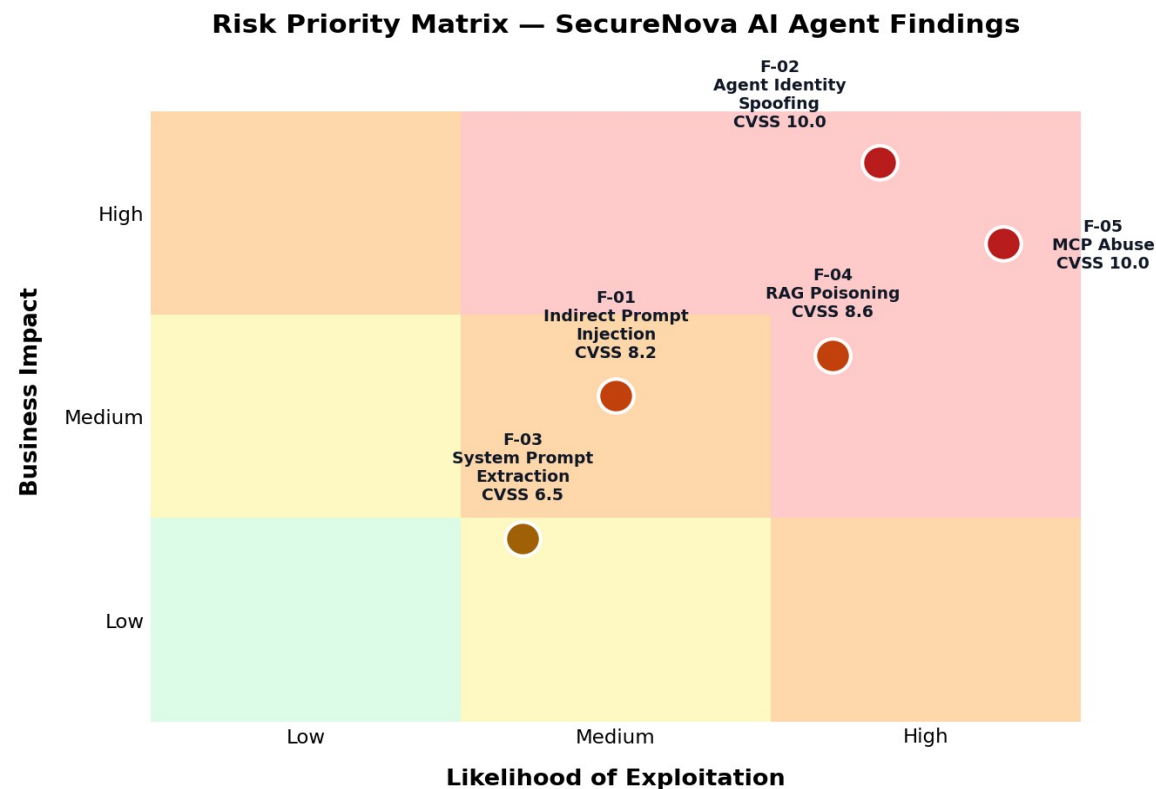
- Phase 1 — Attack Simulation: We deliberately tried to trick the AI agent using techniques a real attacker might use — hiding malicious instructions inside documents it reads, impersonating a trusted system to get it to approve a payment, and tricking it into revealing information it should keep private. Every attempt succeeded against the unprotected agent — this told us exactly where the real risk was.
- Phase 2 — Defense and Verification: We then built specific protections for each weakness found, and re-ran every single attack against the protected version. Every attack that previously succeeded was blocked. We measured this precisely: attack success dropped from 100% to 0%.

Standards We Measured Against

Rather than rely on gut feeling, we scored every finding using CVSS 3.1 — an industry-standard 1-10 severity scale used across the security industry (10 being the most severe) — and cross-checked our defenses against two widely recognized frameworks: the OWASP Top 10 for AI Language Models (a well-known checklist of common AI weaknesses) and the NIST AI Risk Management Framework (a U.S. government framework for managing AI risk responsibly). This ensures our findings and fixes aren't just our own opinion — they're grounded in recognized best practice.

Risk Priority Matrix

The chart below plots all 5 findings by how likely they are to be exploited and how much business impact they would cause if exploited. Each point is labeled with its industry-standard severity score (CVSS).



The two findings in the top-right (red) zone — Agent Identity Spoofing and MCP Abuse — represent the highest business risk: both are easy to trigger and both could cause real financial or data-privacy harm (an unauthorized \$50,000 transfer, and an unauthorized export of customer records, respectively). These were prioritized first, and both are now fully blocked.

Top 5 Recommendations

Each recommendation below is already built and verified working in this project, ready to be adopted as standard practice.

#	Recommendation	Effort	Business Rationale
1	Verify AI agents' identities cryptographically before they act on each other's instructions	Medium (1-2 weeks)	Prevents a fake internal message from tricking one AI system into approving a real financial transaction. This closes our single highest-risk finding (a simulated \$50,000 unauthorized transfer) and is already built and tested.
2	Filter what the AI reads and says, in both directions	Medium (1 week)	Stops the AI from being tricked by hidden instructions in documents it processes, and stops it from accidentally leaking internal credentials in its replies — even if a new trick gets past the first layer of defense.
3	Shorten how long AI login sessions stay valid, and refresh them safely	Low (2-3 days)	If a login credential is ever accidentally exposed, this shrinks the window an attacker has to misuse it from potentially unlimited to just 5 minutes, and ensures a stolen credential can't be reused after refresh.
4	Automatically watch for unusual AI behavior	Medium (1 week)	Gives the security team an early-warning system — unusual activity (like a sudden spike in requests, or an AI suddenly asking for more access than normal) is flagged automatically instead of only being discovered after something goes wrong.
5	Put clear, written rules in place for how AI systems are set up and retired	Low (1 week to write; ongoing to follow)	Makes sure every new AI feature the company builds follows the same safety standards from day one, rather than each team inventing their own approach — this is what keeps the company audit-ready and consistent as AI use grows.

Together, these five recommendations reduced the measured attack success rate against SecureNova's AI agent from 100% to 0% across all tested scenarios.